



Threat Actors Don't Care About Your SLA

BSIDES LAS VEGAS

Patrick Garrity

Security Researcher @ VuInCheck

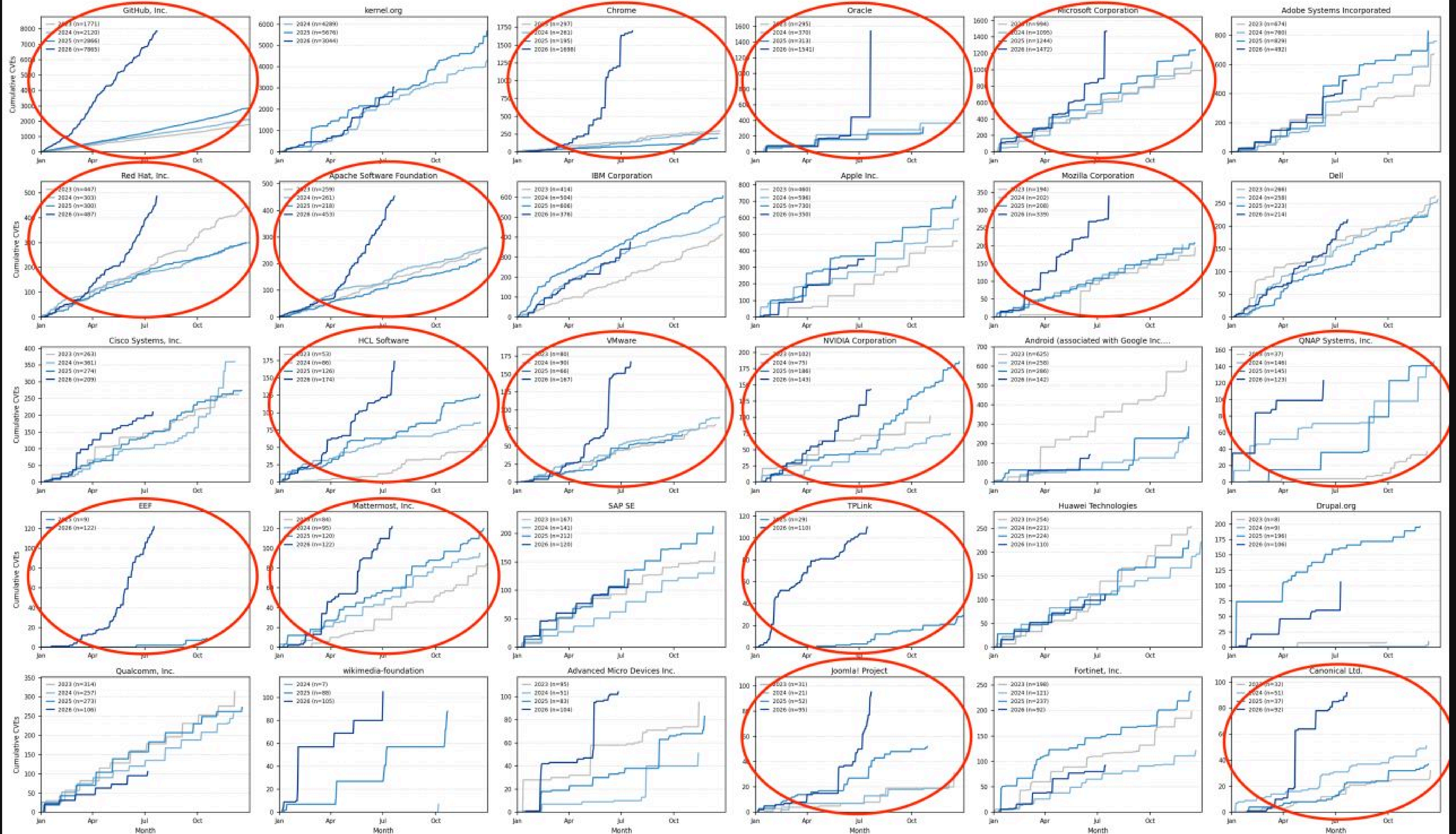
What SLA's Have Historically Looked Like...

Severity	Score	SLA
Critical	9.0 - 10	30 Days
High	7.0 - 8.9	60 Days
Medium	4.0 - 6.9	90 Days
Low	0.1 - 3.9	120 Days

Over the past six months, we've seen a significant change in vulnerability discovery and disclosure resulting in a substantial increase in the number of CVEs disclosed.

This increase has come with warnings about the increase in vulnerability discovery by Autonomous AI systems, creating a “dangerous” scenario for the software ecosystem.

Cumulative CVE publications — top 30 CNAs by 2026 volume, 2023-2026
(y-axis scaled per panel; see legend for totals)

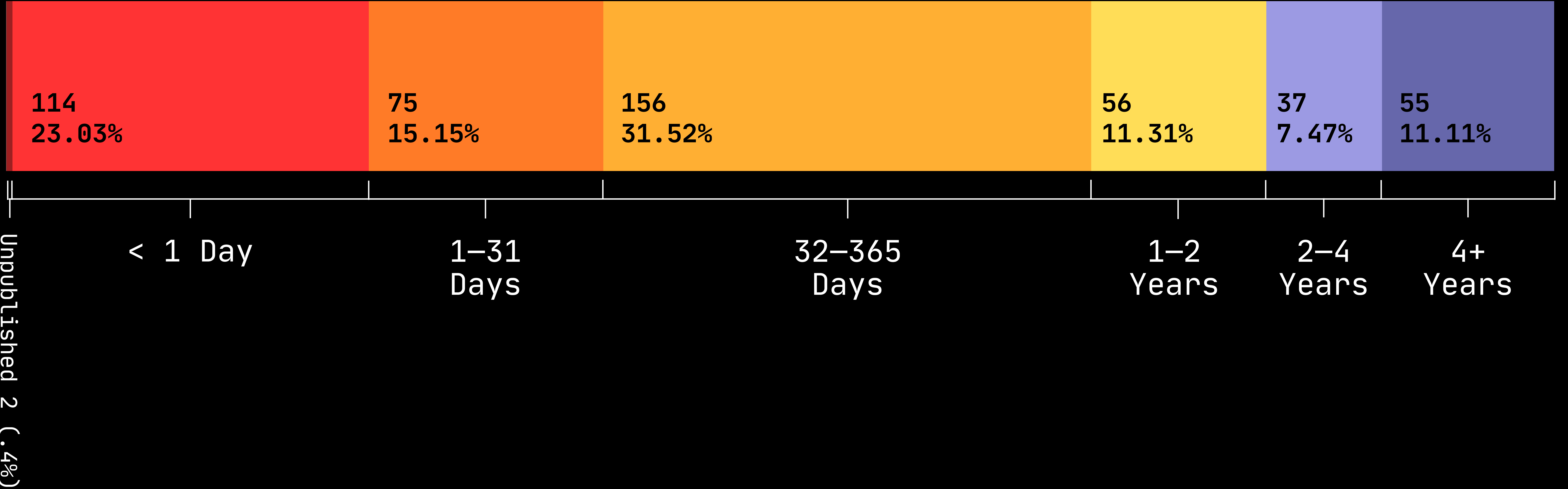


How Fast Are Threat Actors Exploiting Vulnerabilities?

Known Exploited Vulnerabilities

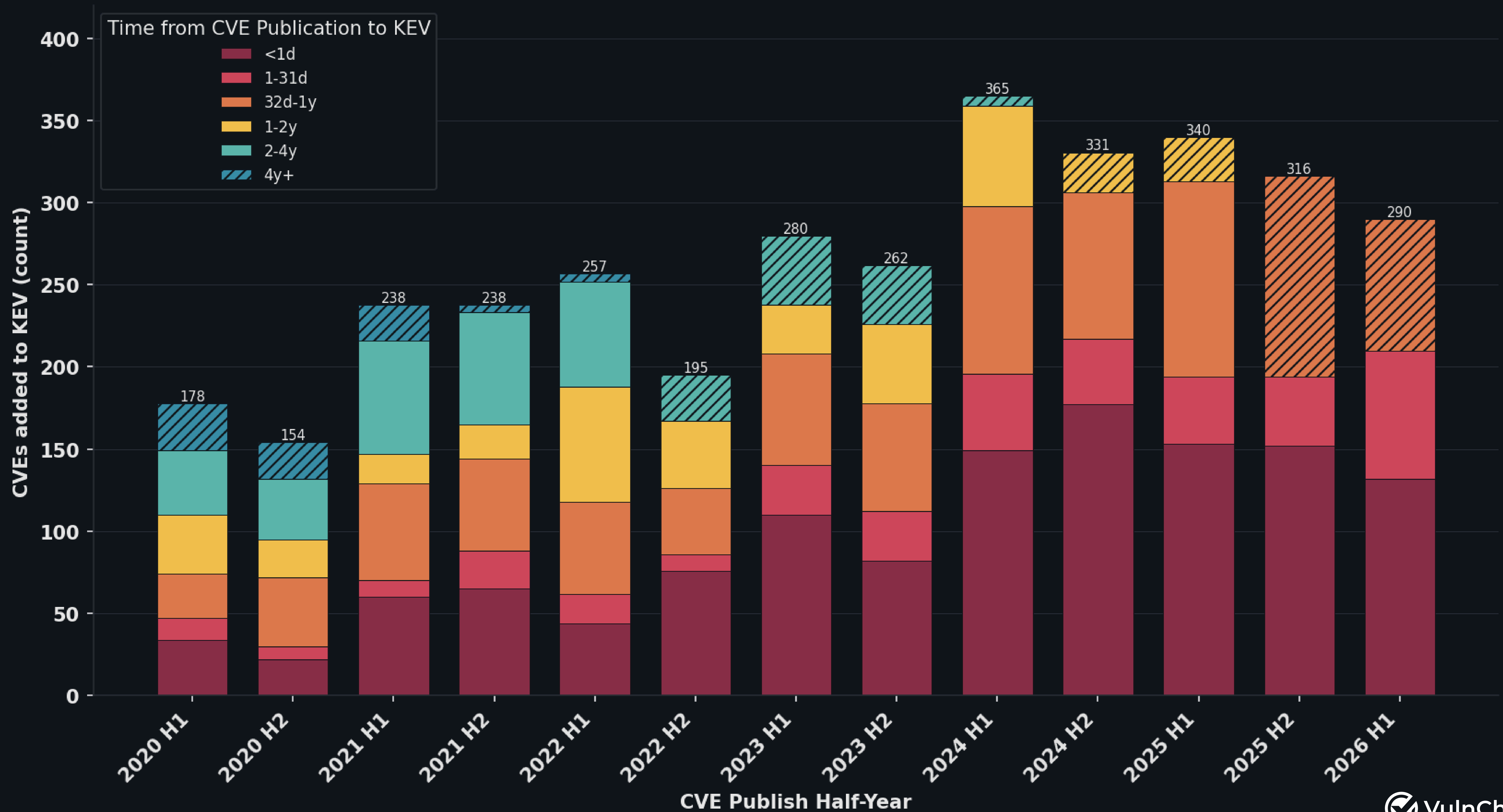
Time From CVE to Exploitation Evidence

Source: VulnCheck KEV 1H-2026



Are New Vulnerabilities Being Exploited Faster?

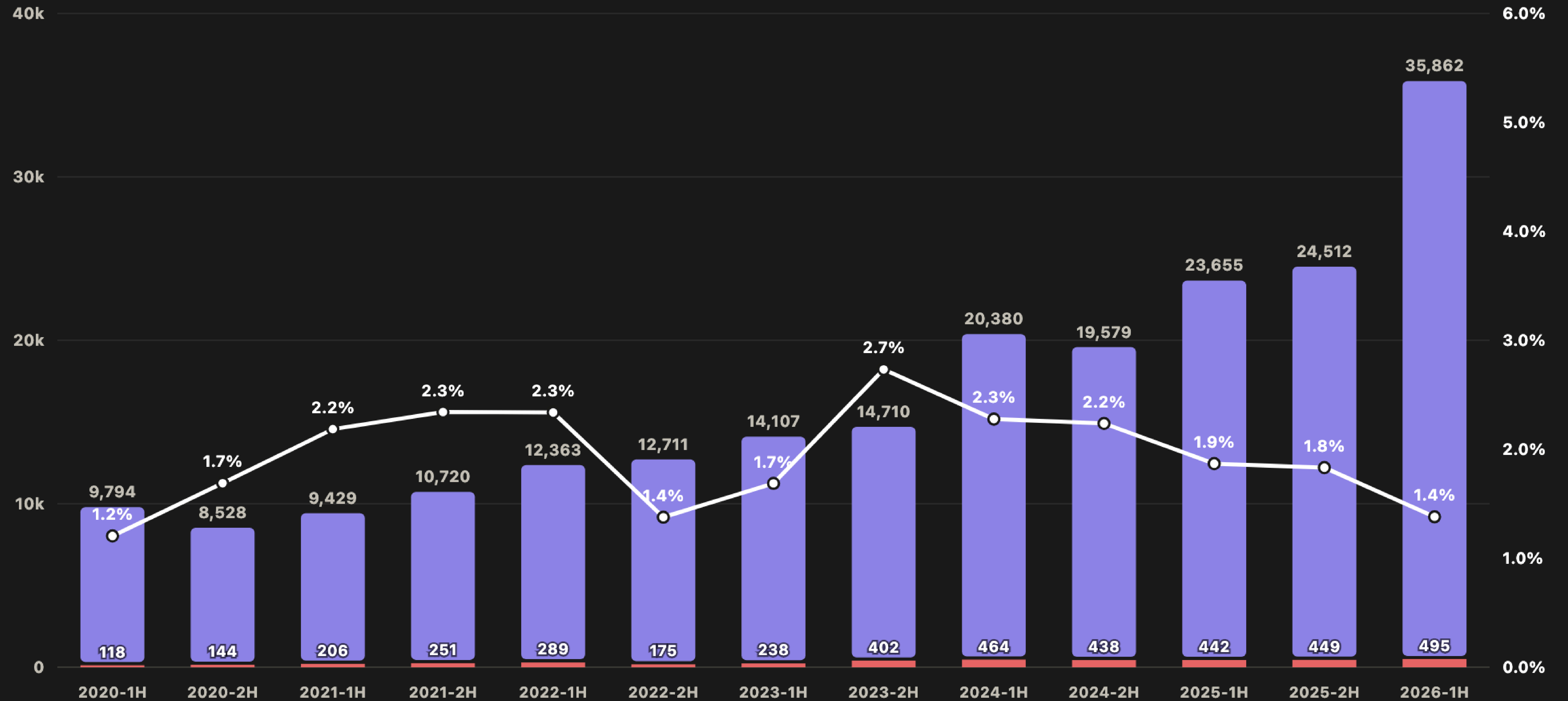
Exploitation Timeline Based on CVE Publish-Date Cohorts



**Is The Rate of Exploitation
Growing at the Same Rate as CVE
Growth?**

CVE Volume, KEVs, & KEV/CVE Ratio

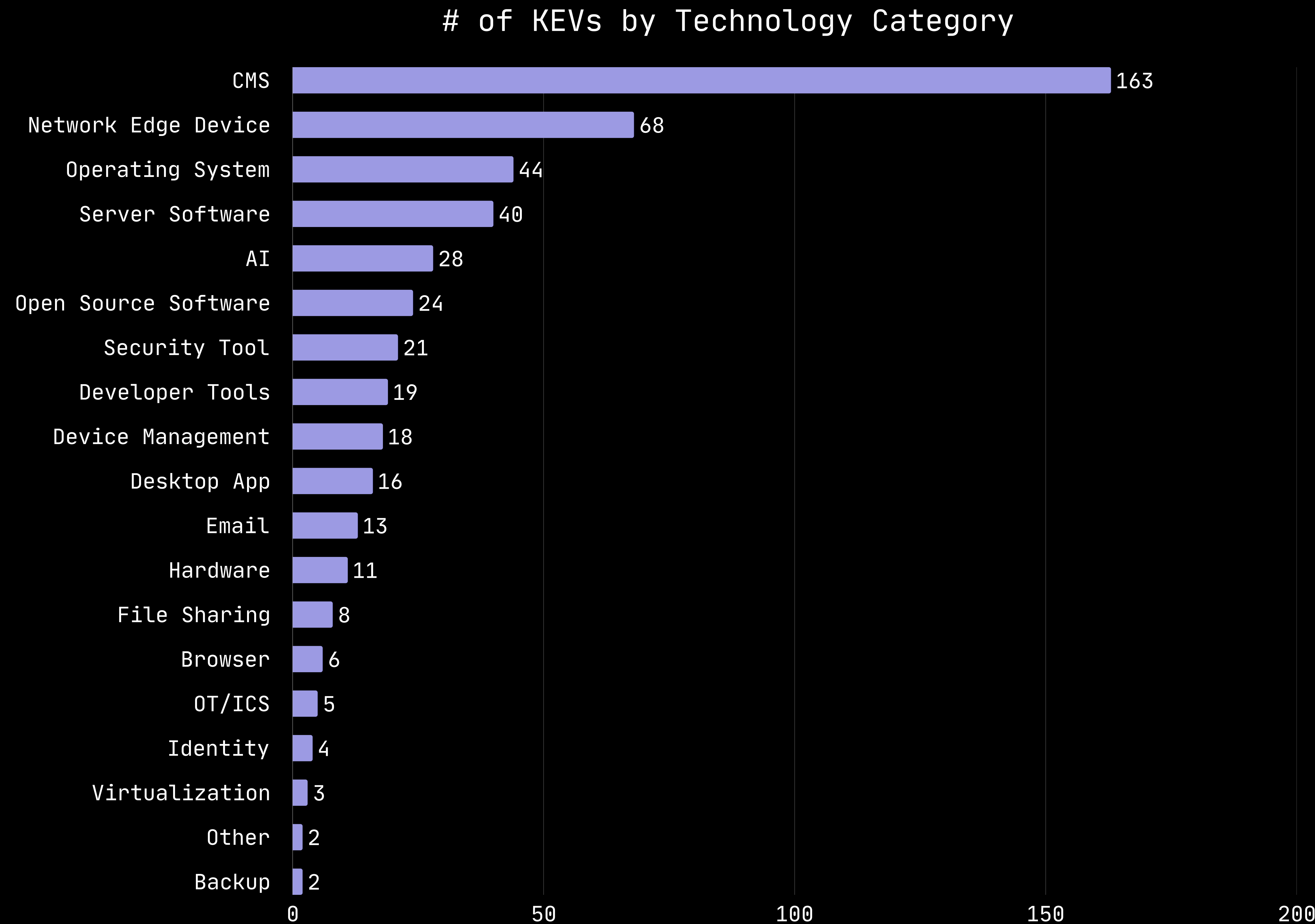
■ CVE's Published ■ KEV's — KEV/CVE Ratio



What Technologies are Being Targeted?

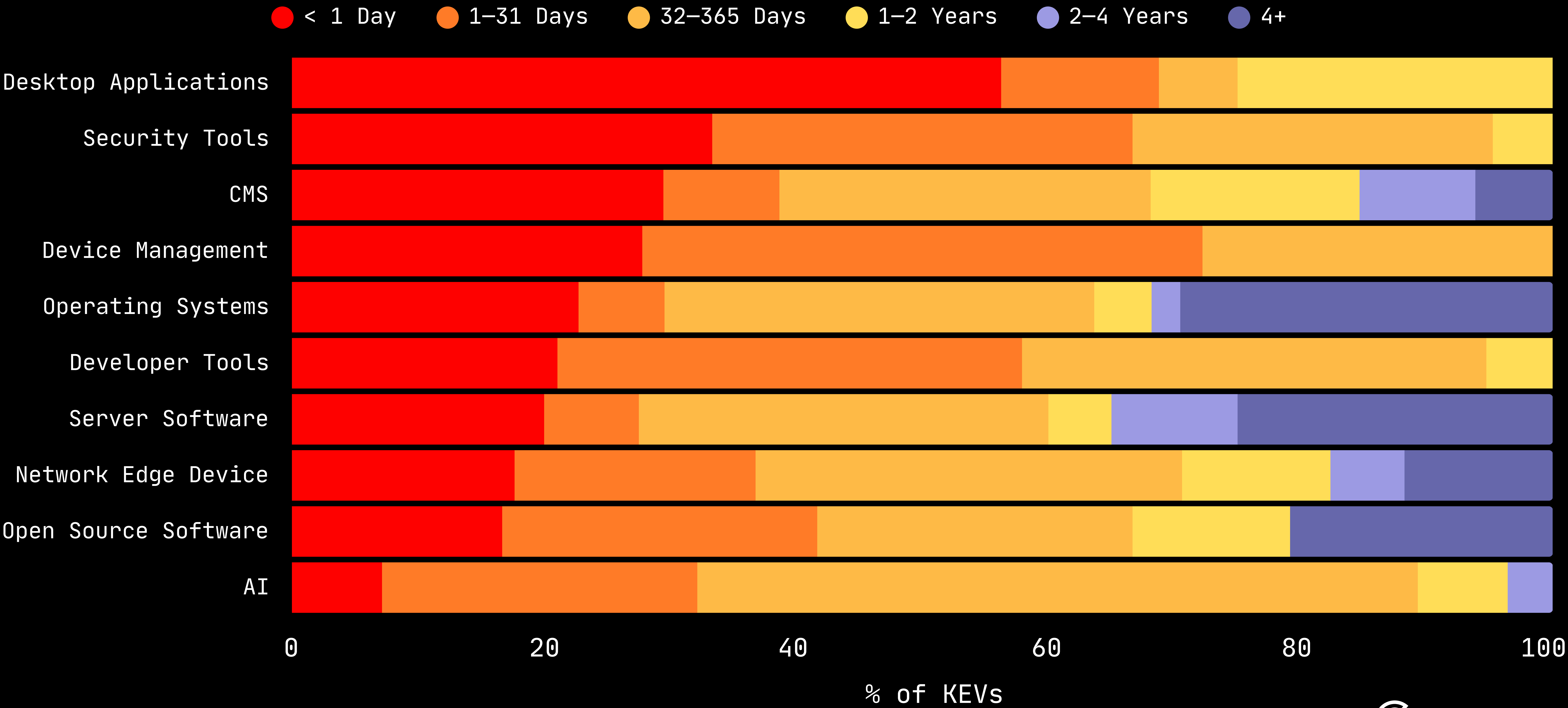
Top Targeted Technologies

Source: VulnCheck KEV
(1H-2026)



Top 10 Targeted Technologies

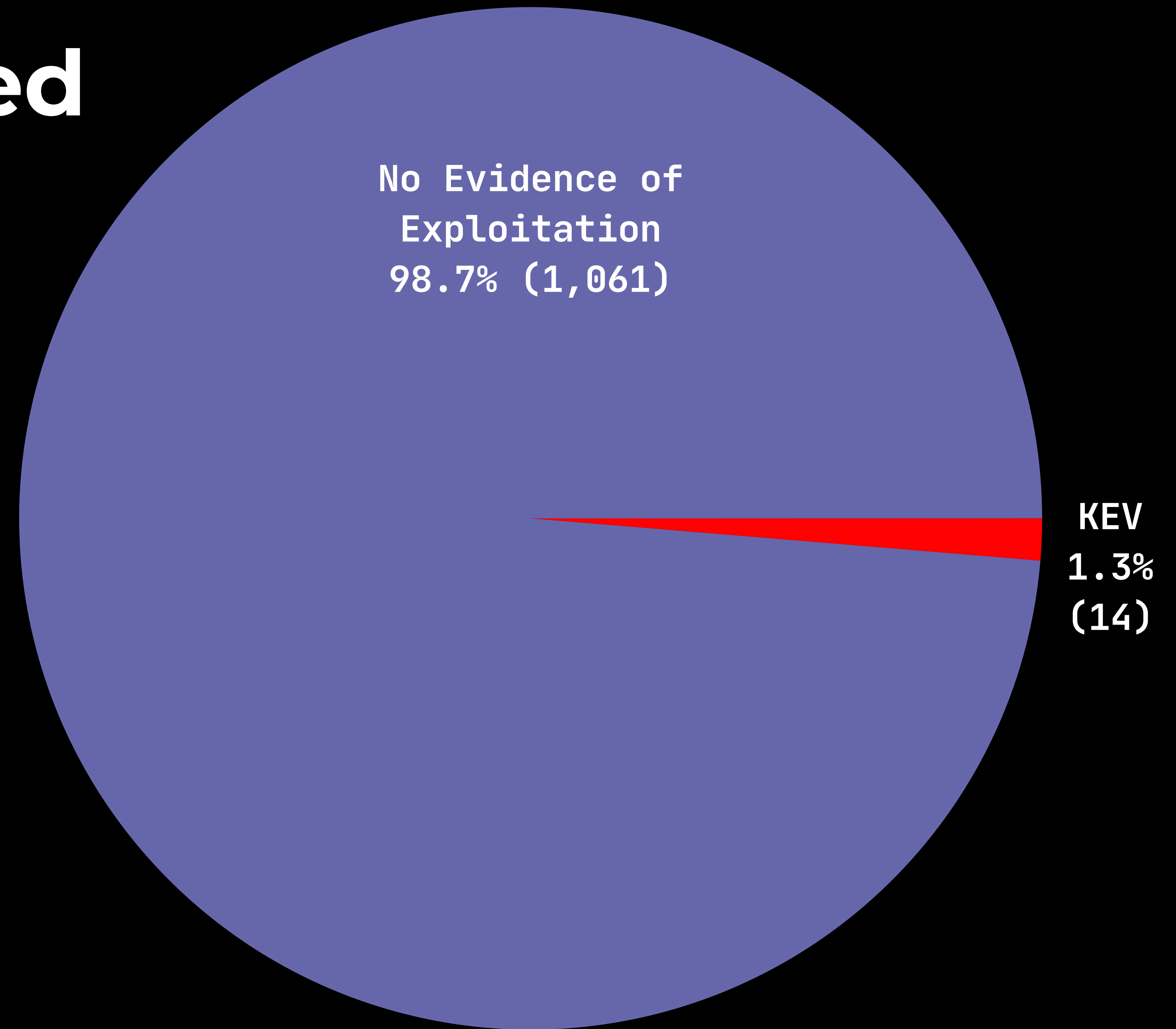
Time From CVE to Exploitation Evidence



Are AI Discovered Vulnerabilities More Dangerous?

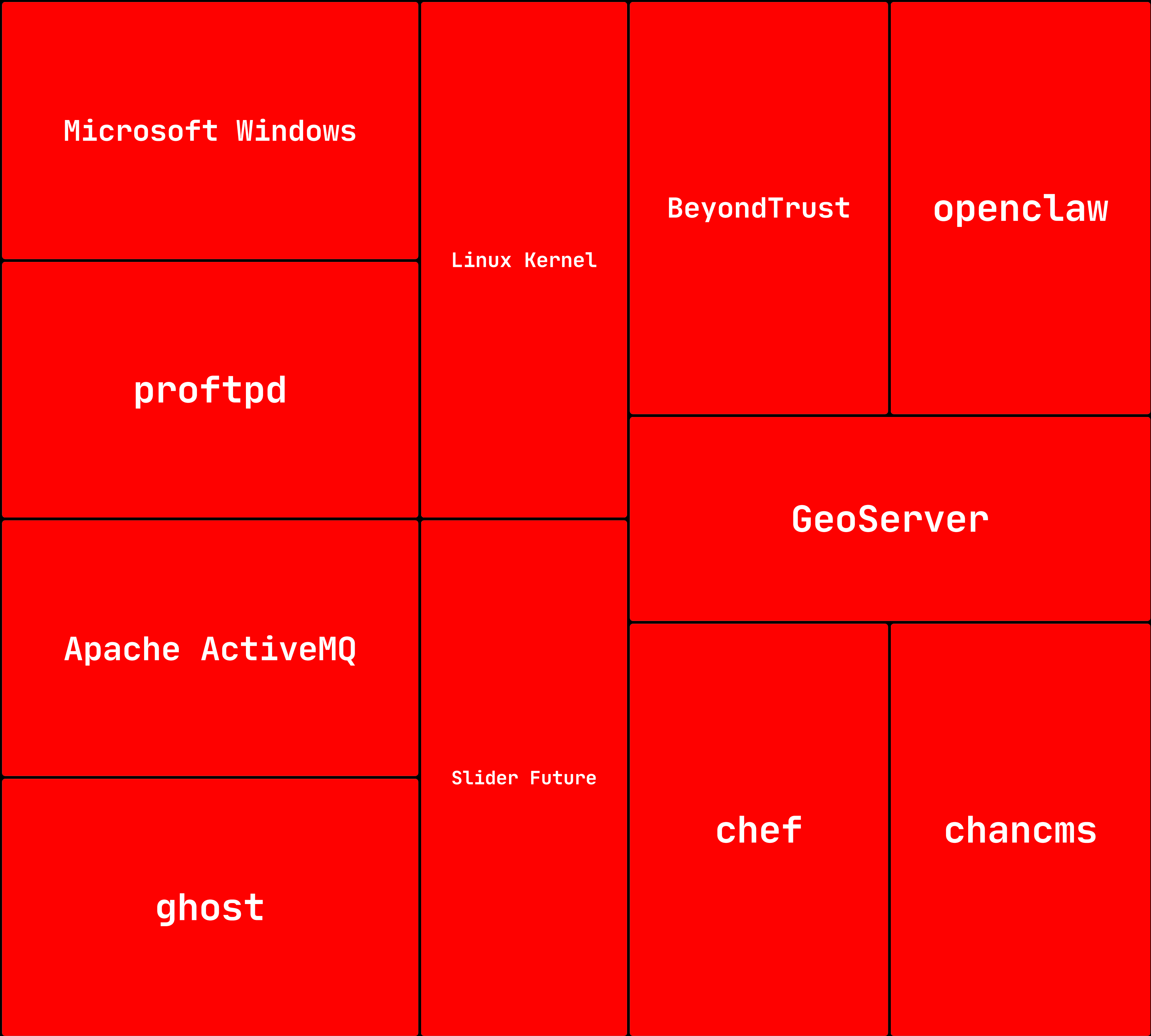
What Percentage of Vulnerabilities Discovered using AI Are Exploited?

1.3% of the 1,061 CVEs
Identified by Berkley
Vulnerability Initiative and
Patrick Garrity's Anthropic
Credited CVEs project are known
to be exploited.



What products were exploited using AI discovered vulnerabilities?

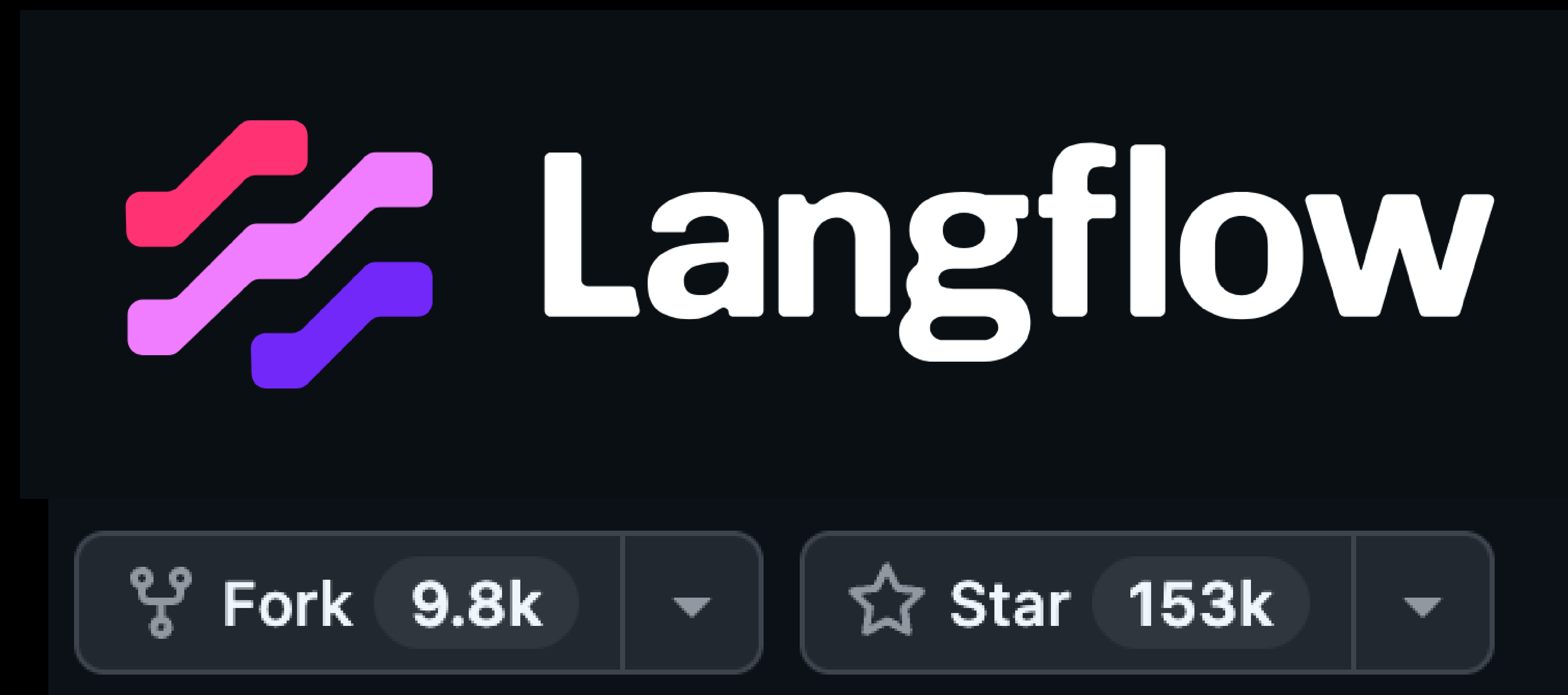
CVEs Identified by Berkley Vulnerability Initiative and Patrick Garrity's Anthropic Credited CVEs project are known to be exploited.



AI Products Exploited In 1H-2026

AI Product							
Langflow				Praison AI	openclaw	Mintplexlabs anythin...	
				Ollama	n8n	MCPJam Inspector	
						lfprojects mlflow	
Majordomo	lollms			internlm lm...	Gradio	comfy	budibase
BerriAI LiteLLM	dify			FlowiseAI		anyscale ray	

Why/How are AI Products Being Targeted?



VulnCheck Canary Visibility into Langflow Attacks

Attacker 1



Initial Access
CVE-2026-0769

Credential
Harvesting

C2 (IRC)
Established

Attacker 2

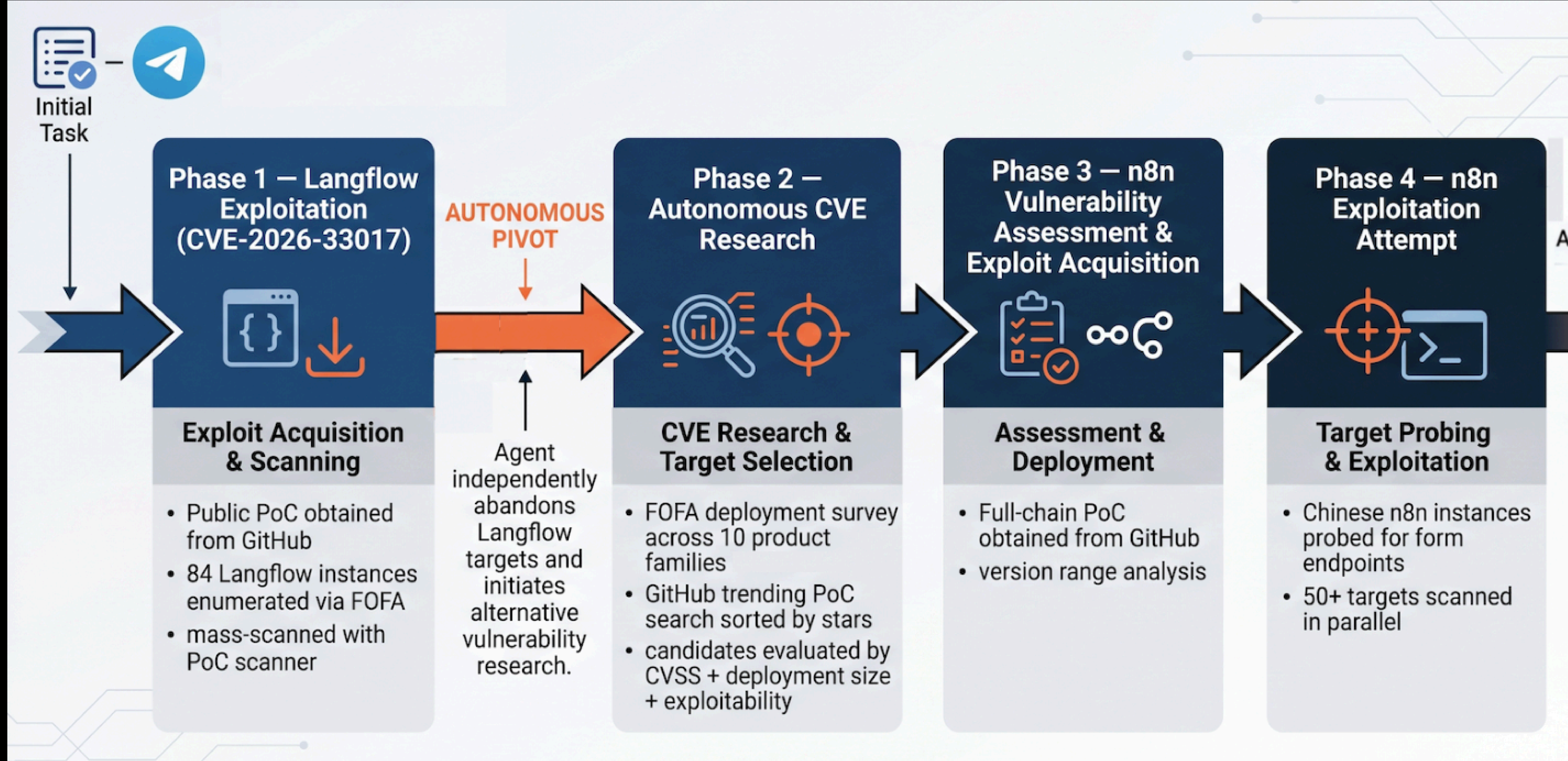


Initial Access
CVE-2025-3248

Crypto Mining
(Pearl Miner XMR)

Scans for Other
Targets

Threat Actor Harnesses AI Models for Autonomous Cyberattacks



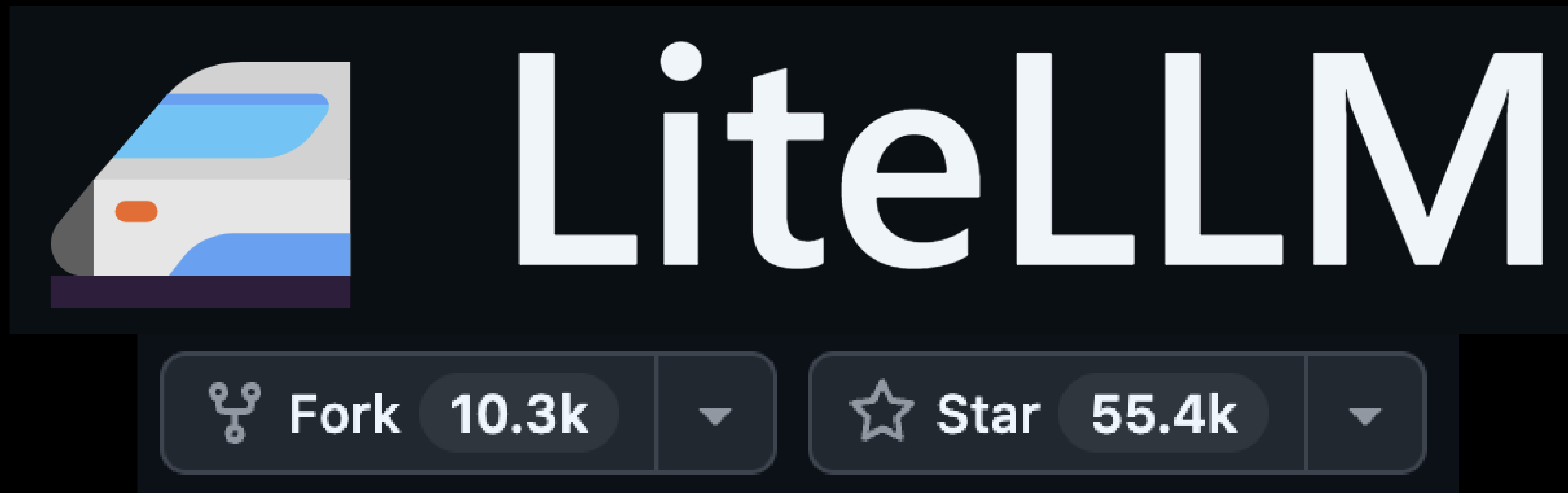
LLM Attack Reasoning...

All three Langflow need public flow ID but no auto_login — stuck. Deployments small (84 alive), exploitable probably 0. Search for larger-scale vulns.

The n8n one with 258 stars and CVSS 10.0 looks extremely promising! n8n is a very popular workflow automation tool similar to Langflow, and it has way more stars on the PoC which suggests it's widely exploited.

Actually, looking at the exploit code again — it needs an UNAUTHENTICATED form with file upload. These forms have auth enabled. Let me check other targets.

Why/How are AI Products Being Targeted?





Yaara Shriki ✓ • 1st
Threat Researcher @ Wiz
6h • 🌐



CVE-2026-59821 + **CVE-2026-59822**

I found two vulnerabilities in LiteLLM. Code injection & auth bypass on MCP endpoints.

Oh and we're seeing at [Wiz](#) active exploitation in the wild.
But that's not where the story ends.
I'll be sharing the full story at [DEF CON](#) 🦴

OffGuard: Breaking the Most Popular AI Gateway from Auth Bypass to Cloud Compromise

Saturday at 17:00 in LVCC - L1 - Exhibit Hall West 3 - 903 (Main Track 5)
60 minutes | Demo 🖥️, Exploit 🦋

Yaara Shriki Wiz (Google)

LiteLLM is the most popular open-source AI gateway, deployed across a third of cloud environments. Organizations route all their LLM traffic through it, trusting it with API keys for every provider, every prompt and response, and connections to external tools via MCP. We broke every layer of its security model.

We present three independent attack vectors, an authentication bypass in the MCP layer, a root-level RCE through sandbox escape, and an SSRF path to cloud credentials, that chain from zero credentials to full cloud infrastructure compromise. We validated every attack at internet scale across thousands of real-world instances and found that nearly 1 in 10 accepted default credentials or required no authentication at all.

Beyond the individual findings, we examine the broader security patterns emerging across AI infrastructure and what they mean for organizations adopting AI gateways as core infrastructure.

“1 in 10 accepted default credentials or required no authentication at all”

Consideration For Defenders

A Change in Physics...

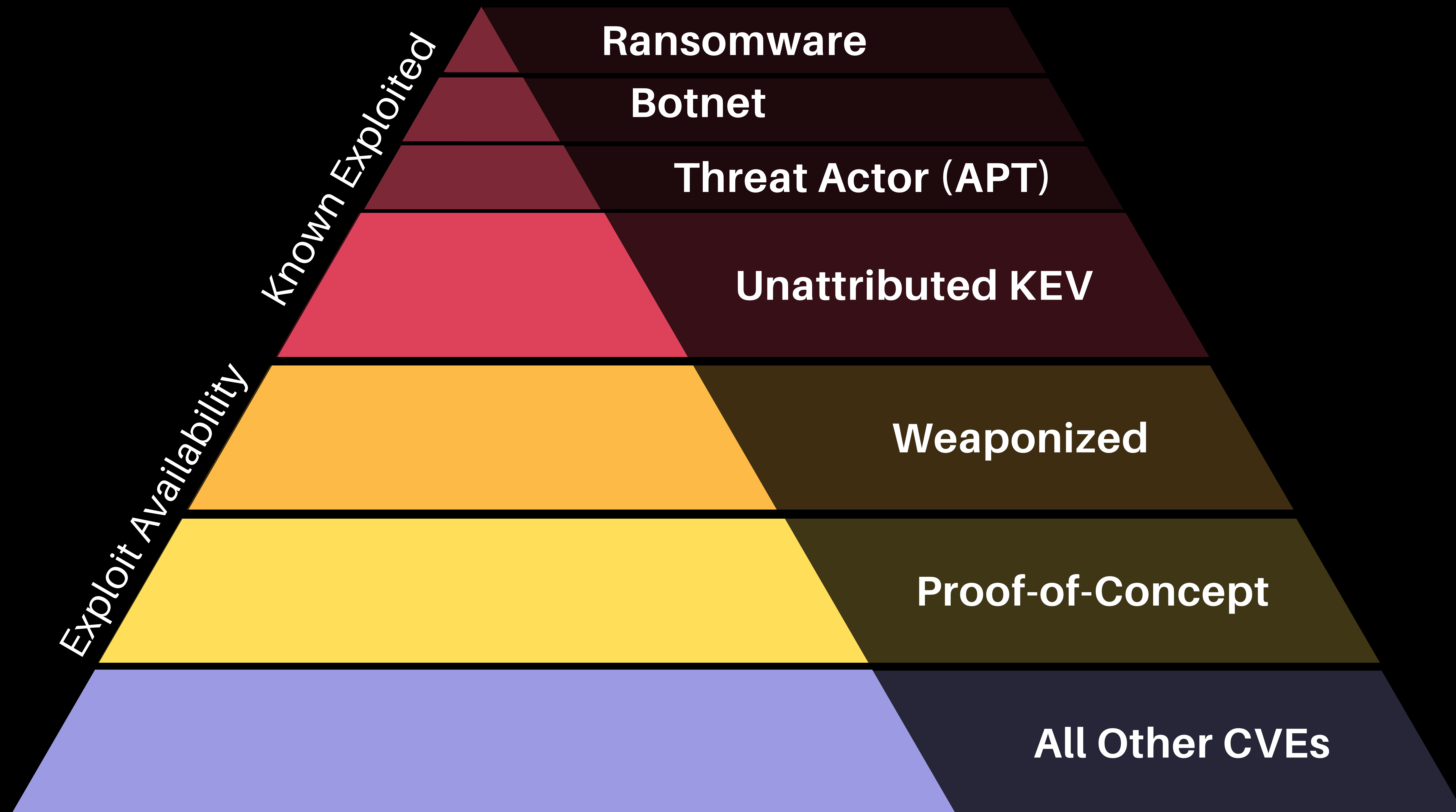


HD Moore's Law

"Casual Attacker power
grows at the rate of
Metasploit"

- Joshua Corman

Vulnerability Threat Matrix



Exploitation Timeline is Likely to Decompress as Threat Actors Operationalize AI Tooling.

- 1. Run The Latest Updated Version of Software**
- 2. Remediate Vulnerabilities w/ Threat Evidence Fast**
- 3. AI Exposes New Attack Surfaces**
- 4. Harden/Prune Publicly Exposed Software/Devices**
- 5. Mitigating Controls & Detection Capabilities**
- 6. Least Privilege Access**

Questions?



Patrick Garrity

SECURITY RESEARCHER

Follow My Work

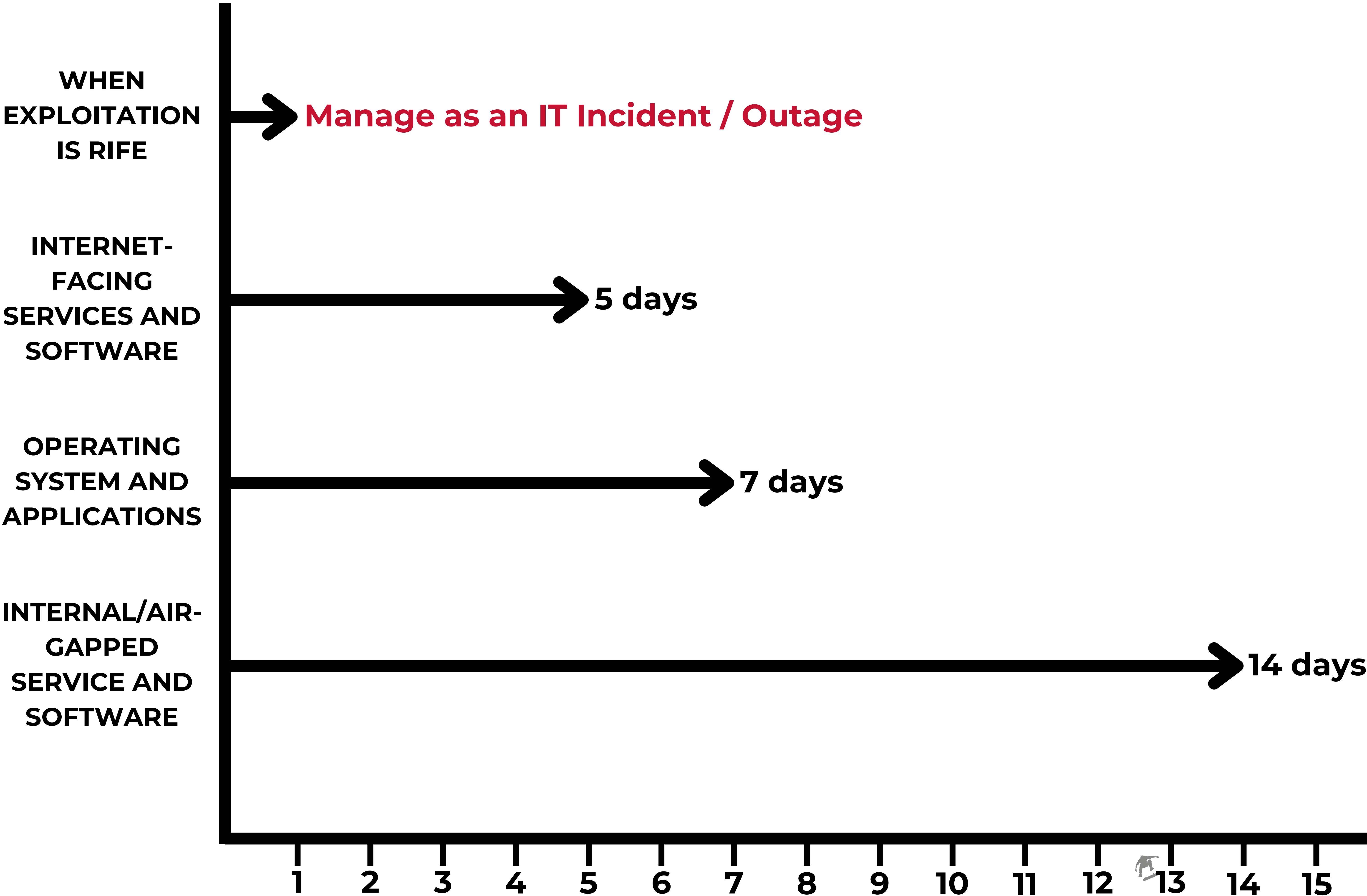


Appendix

Government Guidance

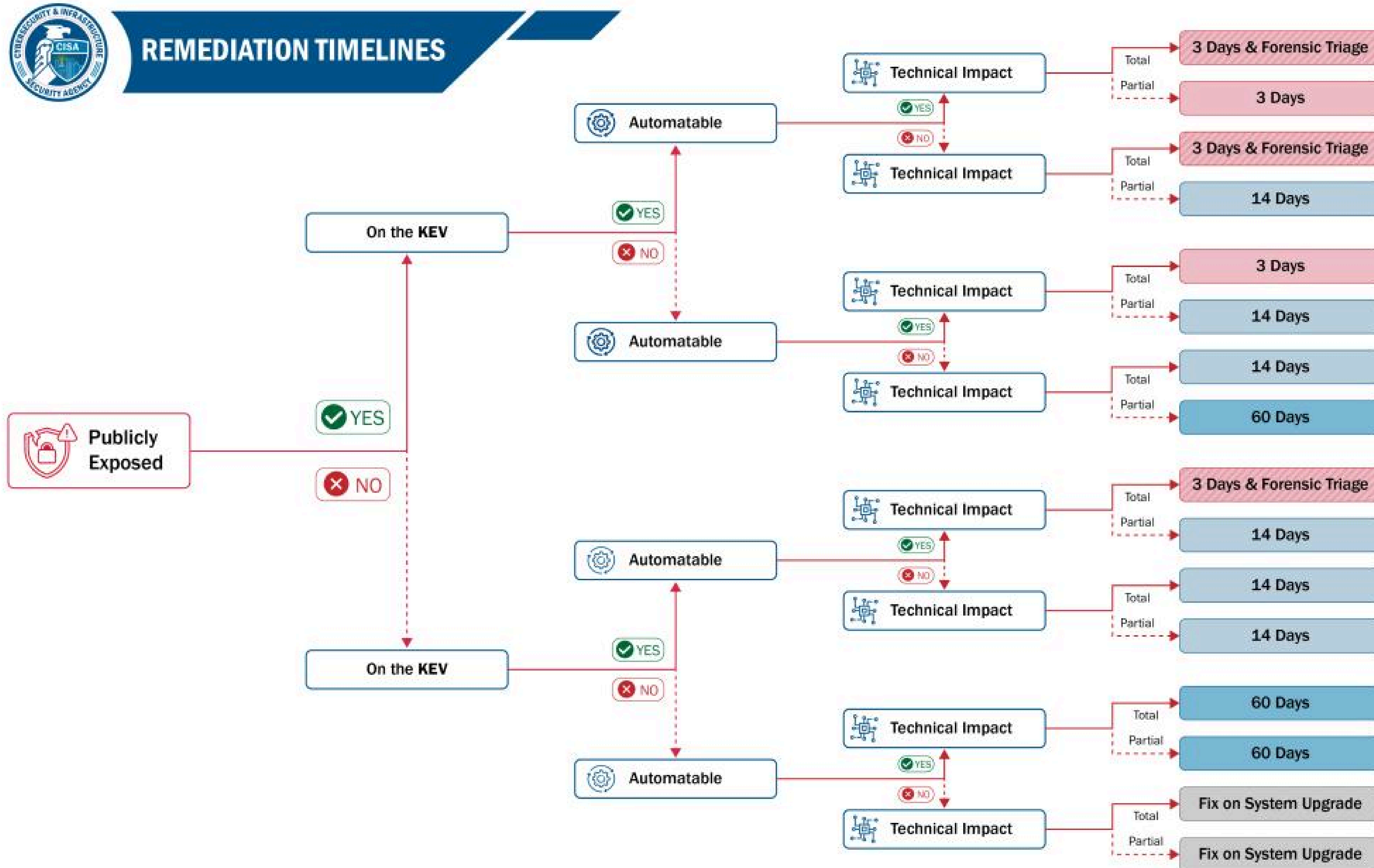
NCSC (UK) Vulnerability Management Best-Practice Timescales

12 February 2024



Recommended # of Days To Complete Update

CISA BOD 26-04: Prioritizing Security Updates Based on Risk



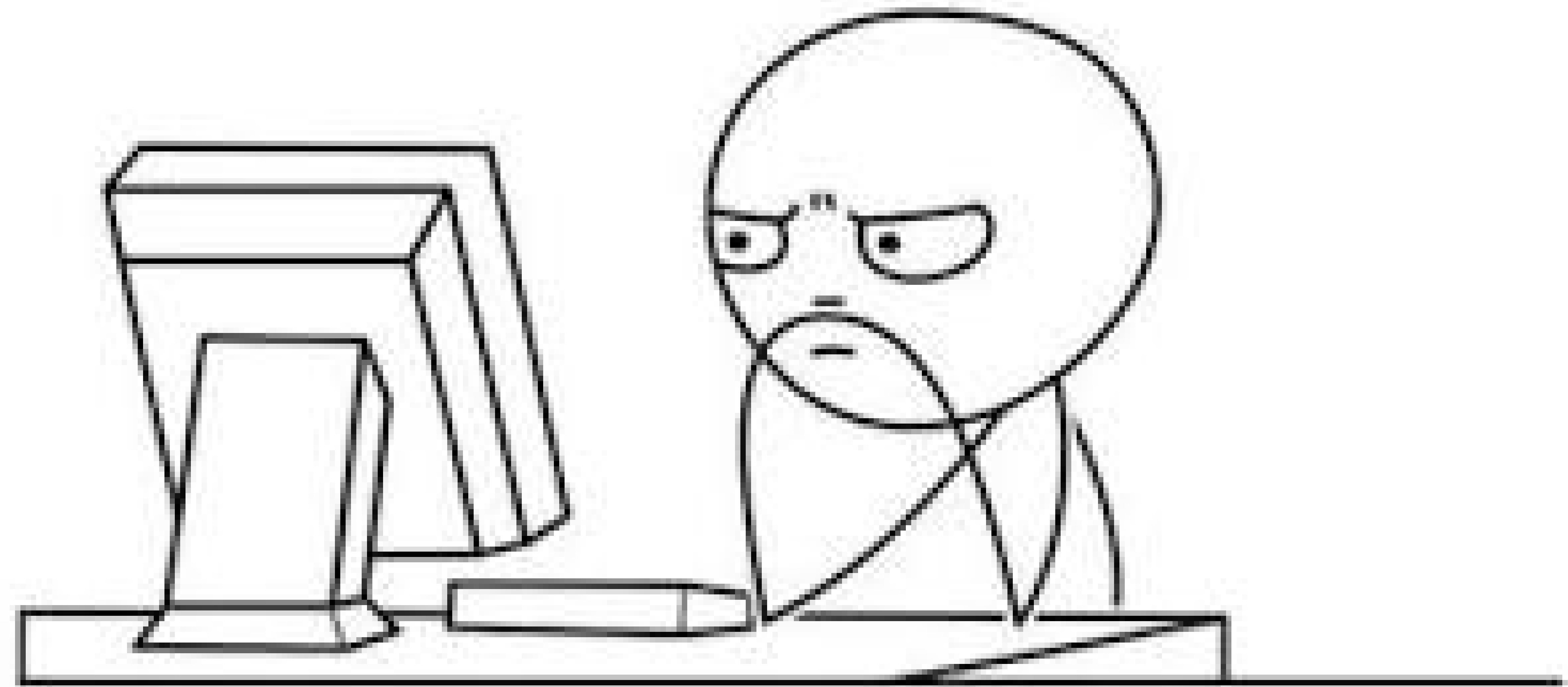
Emerging Threat

1. **Rapid Response**
(Generally Faster)
2. **Internet Facing**
3. **End User Interaction**
4. **Remotely Exploitable**

Vulnerability Debt

1. **Root Cause Analysis**
2. **Improve Patch Management**
3. **Implement Best Practices**
4. **Prune Unused / EOL**
5. **Protect The New AI Attack Surface!**

It doesn't work.... WHY?

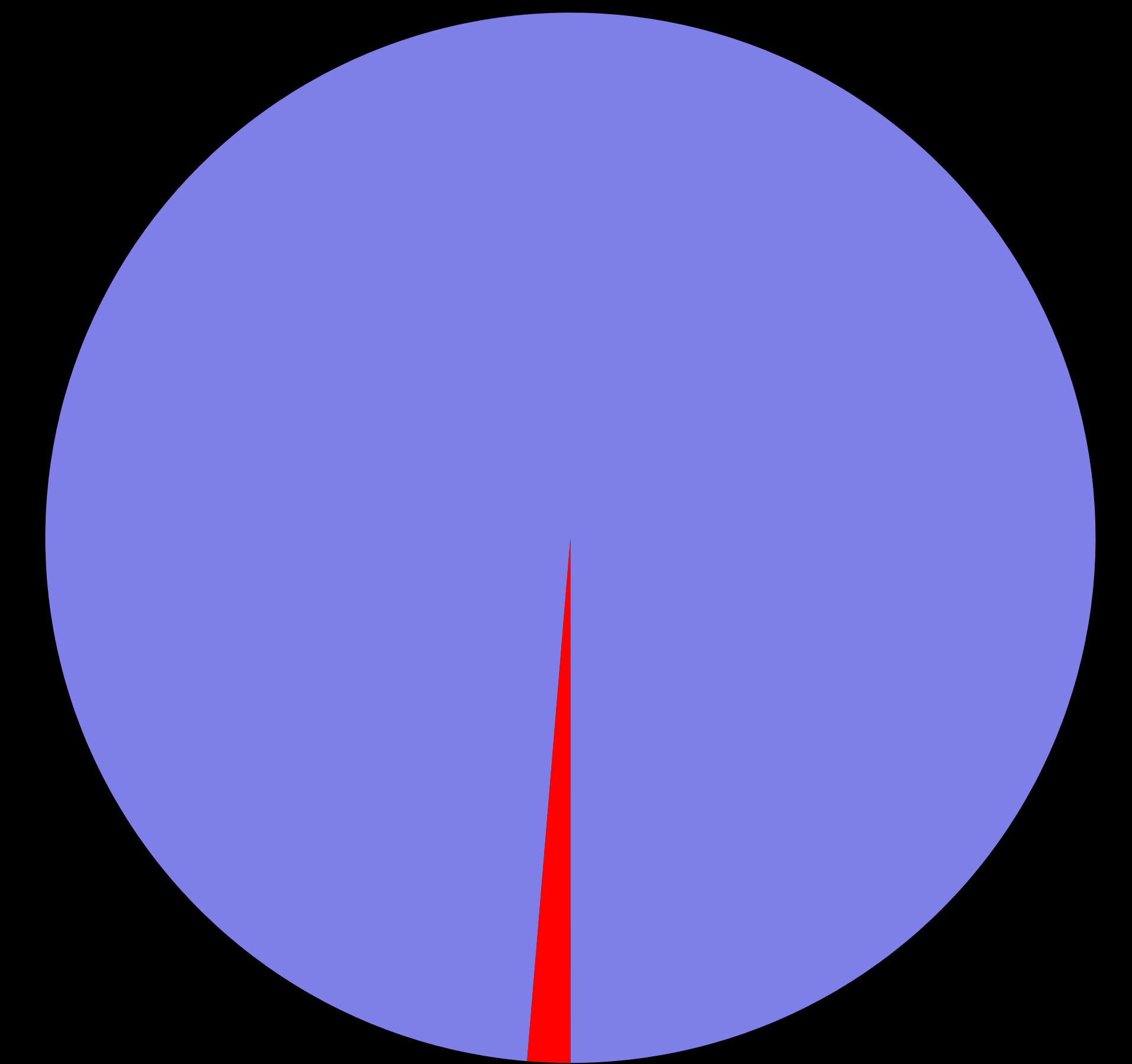
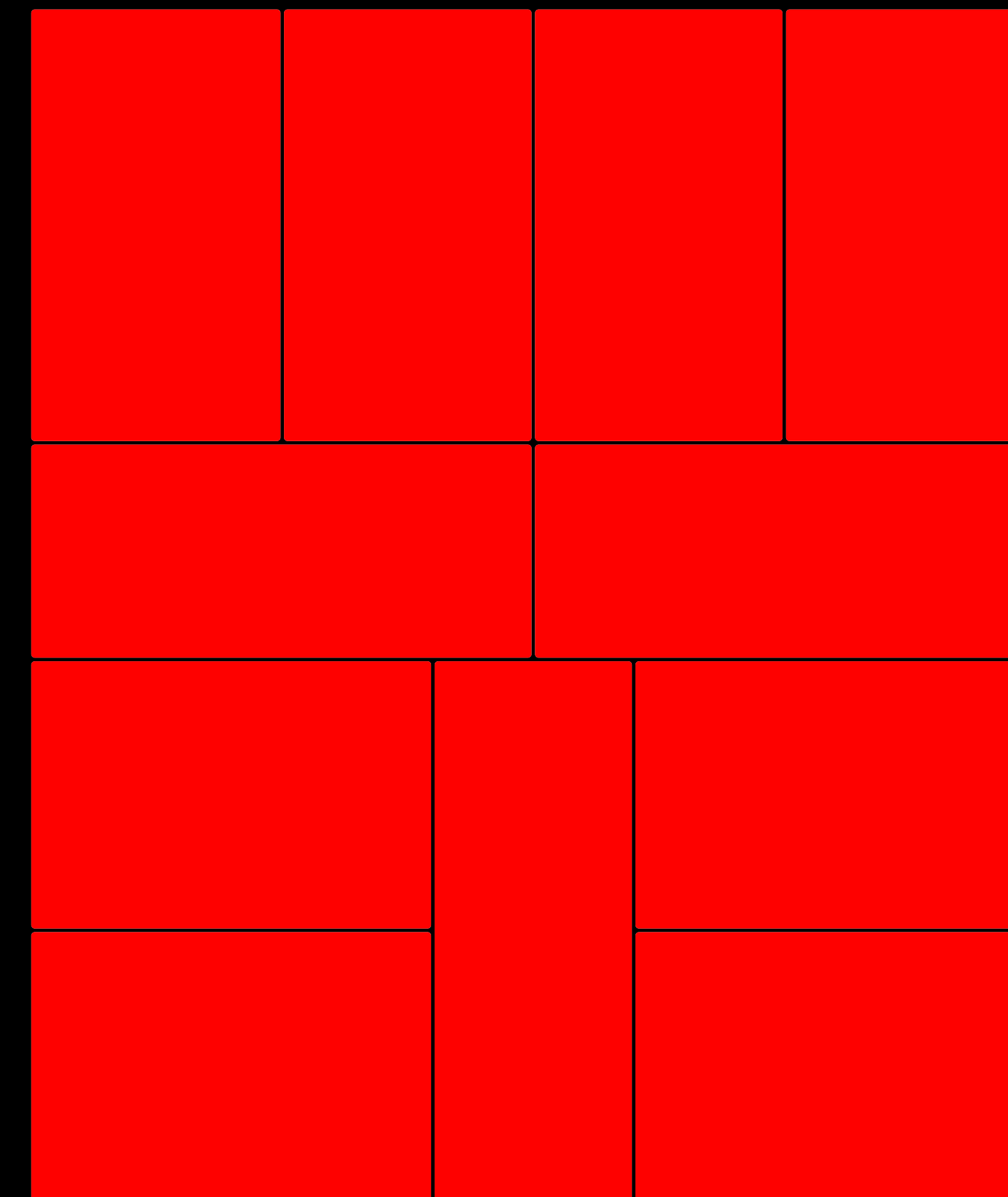


State of Exploitation

1H-2026

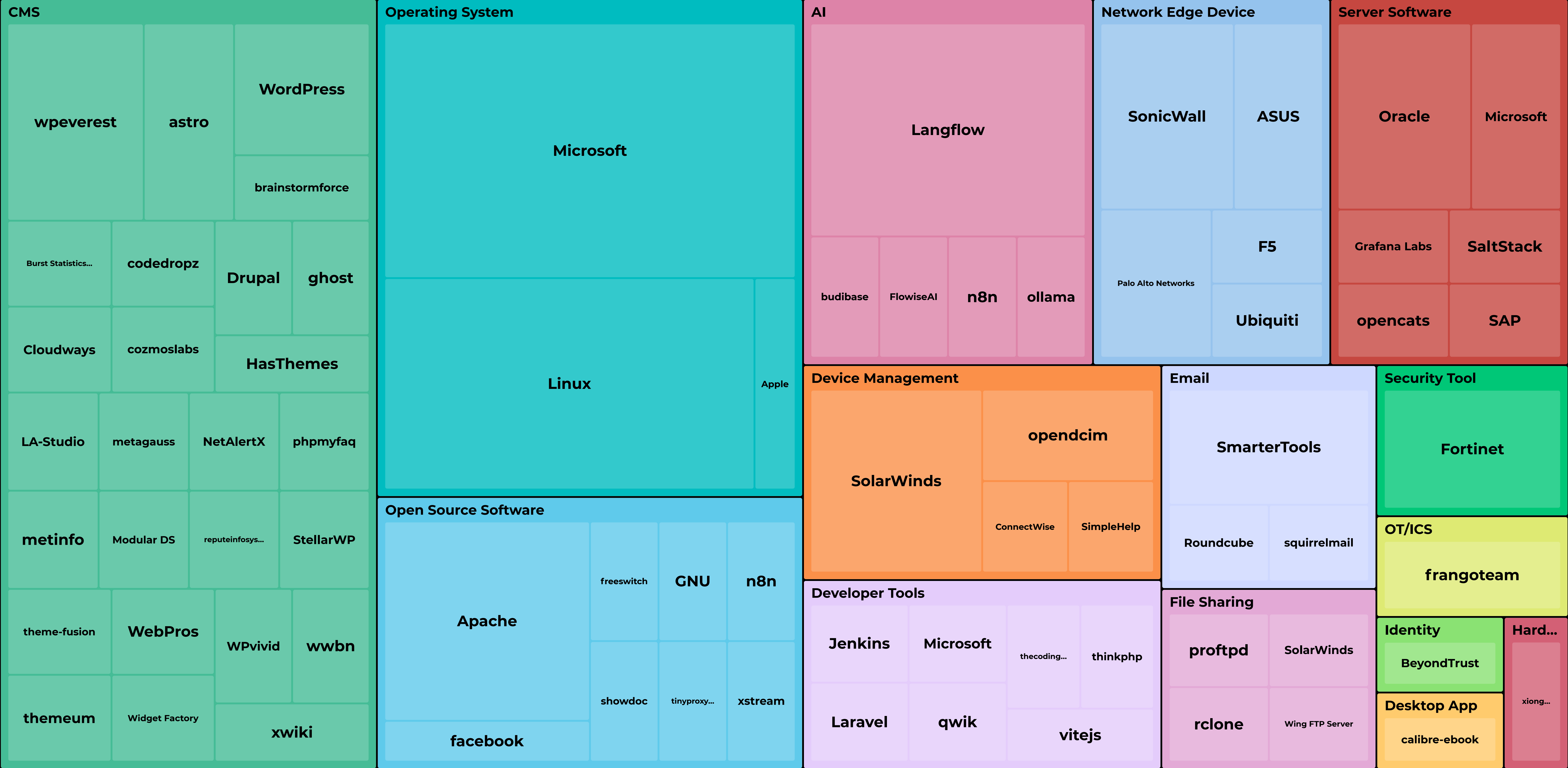
Patrick Garrity

Security Researcher @ VuInCheck



Internet Exposure by Unique KEV Count

Source: VulnCheck Target Intelligence / 1H-2026 VulnCheck KEV Additions





Yaara Shriki ✓ • 1st
Threat Researcher @ Wiz
6h • 🌐



CVE-2026-59821 + **CVE-2026-59822**

I found two vulnerabilities in LiteLLM. Code injection & auth bypass on MCP endpoints.

Oh and we're seeing at [Wiz](#) active exploitation in the wild.
But that's not where the story ends.
I'll be sharing the full story at [DEF CON](#) 🦴

OffGuard: Breaking the Most Popular AI Gateway from Auth Bypass to Cloud Compromise

Saturday at 17:00 in LVCC - L1 - Exhibit Hall West 3 - 903 (Main Track 5)
60 minutes | Demo 🖥️, Exploit 🦋

Yaara Shriki Wiz (Google)

LiteLLM is the most popular open-source AI gateway, deployed across a third of cloud environments. Organizations route all their LLM traffic through it, trusting it with API keys for every provider, every prompt and response, and connections to external tools via MCP. We broke every layer of its security model.

We present three independent attack vectors, an authentication bypass in the MCP layer, a root-level RCE through sandbox escape, and an SSRF path to cloud credentials, that chain from zero credentials to full cloud infrastructure compromise. We validated every attack at internet scale across thousands of real-world instances and found that nearly 1 in 10 accepted default credentials or required no authentication at all.

Beyond the individual findings, we examine the broader security patterns emerging across AI infrastructure and what they mean for organizations adopting AI gateways as core infrastructure.

Internet Exposure by Unique KEV Count

Source: VulnCheck Target Intelligence / 1H-2026 VulnCheck KEV Additions

